

Practical AI Security Manual

IBM Cloud Edition

A beginner-friendly guide to cloud foundations, AI workloads, RAG, agents, MCP, governance, testing, monitoring and incident response.

Alberto (Al) Leiva

Version 1.0 | July 2026

Use only in accounts, projects, and systems you own or are authorized to administer. Technical capability never creates permission.

Table of Contents

In Microsoft Word, right-click the table and select Update Field.

Table of Contents.....	2
How to Use This Manual	3
Cloud and AI Foundations	3
Platform control map	3
Shared Responsibility and Threat Modeling	4
Secure Account and Landing-Zone Design.....	4
Identity, Access and Non-Human Identities	5
Network and Edge Security	5
Data Protection, Encryption and Privacy.....	5
Logging, Detection and Security Posture	6
Workload, Container and Supply-Chain Security	6
AI Lifecycle and Model Risk Management	6
Generative AI and Prompt Security.....	7
RAG Security	7
AI Agents, Tools and MCP	7
Testing and Red Teaming.....	8
Governance, Compliance and Control Mapping.....	8
Incident Response for Cloud AI	8
Practical Sandbox Lab.....	9
Evidence package.....	9
Audit Evidence and Operational Checklists	9
Career Practice and Final Guidance	10
Glossary	10
Official Resources and Further Study	11
Appendix: Minimum Control Baseline	11

How to Use This Manual

This manual teaches a repeatable way to secure AI solutions on IBM Cloud. It starts with cloud fundamentals and moves through identity, data, networking, generative AI, retrieval-augmented generation (RAG), agents, Model Context Protocol (MCP), governance and operations.

Product names and console screens change. The durable skill is learning why a control exists, what risk it reduces, how to verify it and what evidence proves it is operating. Always confirm regional availability, licensing and current documentation before production use.

- Read the chapters in order if you are new to cloud security.
- Experienced practitioners may use the checklists and control tables as a working reference.
- Practice in a separate sandbox with synthetic or public data.
- Record decisions, owners, approvals and test results as you work.

Cloud and AI Foundations

IBM Cloud provides compute, storage, networking, databases, identity, monitoring and AI services. An AI system combines these cloud components with models, prompts, data, code, interfaces and people. Securing only the model leaves most of the system unprotected.

The main administrative structure is enterprise, account, resource groups, regions and service instances. Use that structure to separate production from development, restrict privileges, track costs and place policy boundaries around sensitive workloads.

Secure AI request path

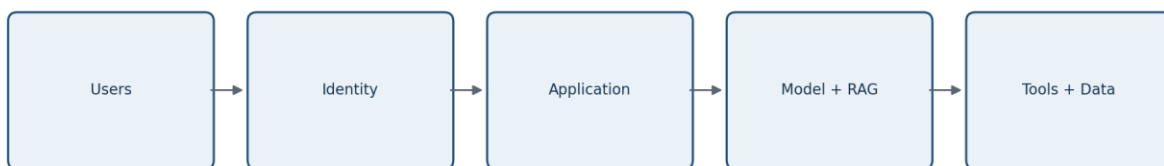


Figure 1. Security controls surround the complete AI request path.

Platform control map

Layer	Platform capability	Security objective
Organization	Enterprise, account, resource groups, regions and service instances	Separate environments, ownership and policy scope.
Identity	IBM Cloud IAM policies, access groups, trusted profiles, service IDs and API keys	Federation, MFA, least privilege and workload identity.
Network	IBM Cloud VPCs, subnets, security groups, network ACLs, Transit Gateway, Direct Link and Cloud Internet Services	Private paths, controlled ingress and explicit egress.

Layer	Platform capability	Security objective
Keys and secrets	IBM Key Protect, Hyper Protect Crypto Services and Secrets Manager	Key ownership, rotation, separation of duties and secret retrieval.
Logs	IBM Cloud Logs, Activity Tracker Event Routing, Monitoring and Event Notifications	Protected evidence, detection and investigation.
Posture	IBM Cloud Security and Compliance Center and Workload Protection	Continuous configuration and workload findings.
AI platform	IBM watsonx.ai, watsonx.governance and watsonx.data	Model lifecycle, evaluation, deployment and governance.

- IaaS: the customer manages operating systems, applications, identities and data.
- PaaS: the provider manages more of the runtime, while the customer still manages access, configuration and data.
- SaaS: the provider operates the application, but the customer remains responsible for users, sharing, data use and business decisions.
- AI services add model behavior, prompt handling, evaluation and human oversight responsibilities.

Shared Responsibility and Threat Modeling

Cloud providers secure the underlying facilities and service platform. Customers secure their tenants, configurations, identities, workloads, data and use of AI outputs. Managed services reduce operational work but do not remove accountability.

Threat modeling asks what you are building, what can go wrong, what controls exist and how you will know when they fail. Repeat it when the model, data source, tool permission, deployment pattern or business purpose changes.

- Map trust boundaries among users, applications, models, vector stores, tools and external services.
- Identify sensitive inputs, outputs, credentials, embeddings, logs and training data.
- Consider misuse, prompt injection, excessive agency, data poisoning, insecure output handling and denial of service.
- Assign an owner and measurable verification method to every important mitigation.

Secure Account and Landing-Zone Design

A secure landing zone establishes account organization, identity integration, network patterns, logging, encryption, guardrails and incident-response access before teams deploy workloads. In IBM Cloud, organize resources through enterprise, account, resource groups, regions and service instances.

Separate production, development, security tooling and shared services. Centralize security logs in a location that workload administrators cannot quietly alter. Use infrastructure as code so important settings are reviewable and repeatable.

- Document account ownership and emergency contacts.
- Require multifactor authentication for human administrators.
- Create separate production and nonproduction boundaries.

- Enable organization-wide audit collection before onboarding applications.
- Define approved regions, services, images, key-management patterns and tagging rules.
- Test backup restoration and emergency access.

Identity, Access and Non-Human Identities

IBM Cloud IAM policies, access groups, trusted profiles, service IDs, and API keys control who can access resources and what they can access. Human accounts should use federation and MFA. Workloads should use short-lived, platform-native identities instead of embedded API keys whenever possible.

Non-human identities include service accounts, service IDs, workload identities, agent identities, CI/CD credentials and integration tokens. They frequently accumulate excessive privilege and outlive their owners, so they require inventory, ownership, rotation and monitoring.

- Grant least privilege at the narrowest practical resource scope.
- Separate administrative, deployment, runtime and audit roles.
- Avoid shared accounts and long-lived credentials.
- Require approval for high-risk permissions and production access.
- Review dormant identities, unused permissions and orphaned keys.
- Give each AI agent its own identity and limit every callable tool.

Network and Edge Security

Use IBM Cloud VPCs, subnets, security groups, network ACLs, Transit Gateway, Direct Link and Cloud Internet Services to create layered network boundaries. Private endpoints reduce exposure, but "private" does not automatically mean "trusted". Inspect traffic, limit routes, and apply identity controls even inside private networks.

AI applications commonly call model endpoints, data stores, SaaS APIs, and tools. Create an explicit egress policy so a compromised prompt or agent cannot freely send information to the internet.

- Default-deny inbound access and permit only documented flows.
- Use private service connectivity where supported.
- Restrict administrative access through managed bastion or approved private access.
- Protect public endpoints with WAF, DDoS controls, rate limits and bot defenses.
- Log flow and edge events and alert on unusual destinations or volume.
- Test DNS, routing and failover behavior.

Data Protection, Encryption and Privacy

Classify data before it reaches IBM Cloud Object Storage, databases, watsonx.data and Knowledge Catalog, model prompts, fine-tuning jobs or vector indexes. Use IBM Key Protect, Hyper Protect Crypto Services and Secrets Manager to protect keys and secrets. Encryption is necessary, but access decisions, retention and deletion remain equally important.

Embeddings can preserve sensitive meaning even when they do not reproduce the original text exactly. Treat vector stores, evaluation datasets, prompt histories and model outputs according to the classification of their source data.

- Collect only data needed for the approved purpose.
- Block secrets and regulated data from prompts unless explicitly approved.
- Use customer-managed keys where risk, regulation or contract requires them.

- Separate key administrators from data administrators.
- Define retention and defensible deletion for prompts, outputs, logs and embeddings.
- Test backup encryption and restore permissions.

Logging, Detection and Security Posture

IBM Cloud Logs, Activity Tracker Event Routing, Monitoring and Event Notifications provide operational and security evidence. IBM Cloud Security and Compliance Center and Workload Protection help identify configuration weaknesses and workload risk. Route high-value events to a protected central store and, when appropriate, a SIEM.

Do not log full prompts or retrieved documents by default. Logging must balance investigative needs with privacy and the risk of exposing secrets. Prefer identifiers, hashes, classifications, policy decisions and redacted excerpts.

- Administrative sign-ins and policy changes
- Credential, key and secret lifecycle events
- Network, firewall and public exposure changes
- Model endpoint, agent and tool invocation activity
- Guardrail blocks, prompt-injection detections and unsafe-output events
- Data access, exports, deletions and unusual volume
- Logging pipeline failures and retention changes

Workload, Container and Supply-Chain Security

Red Hat OpenShift on IBM Cloud, IBM Cloud Kubernetes Service, Container Registry and Code Engine can host AI applications and supporting services. Secure the build pipeline as carefully as the runtime: a trusted cluster cannot compensate for a malicious package, model or container image.

Use signed artifacts, controlled registries, software bills of materials, vulnerability scanning and deployment approvals. Pin dependencies and model versions where practical, and document the source and license of every model and dataset.

- Use minimal, supported base images and run as non-root.
- Scan code, dependencies, images, infrastructure templates and secrets.
- Sign release artifacts and verify signatures during deployment.
- Apply admission policies and restrict privileged containers.
- Use separate build and runtime identities.
- Monitor drift from approved configuration and model versions.

AI Lifecycle and Model Risk Management

IBM watsonx.ai, watsonx.governance, and watsonx.data support parts of the AI lifecycle. Security begins with a documented use case, an accountable owner, and a risk classification—not with a model endpoint.

Evaluate quality and safety against the intended population and environment. A model that performs well in a demonstration may fail with different languages, adversarial prompts, incomplete data or real business pressure.

- Define purpose, prohibited uses and human decision authority.
- Record model provider, version, data sources, license and known limitations.
- Create measurable acceptance thresholds for accuracy, safety, privacy, latency and cost.
- Test bias, hallucination, prompt injection, data leakage and abuse cases.

- Approve release through independent risk and business review.
- Monitor after deployment and define rollback triggers.

Continuous AI security lifecycle

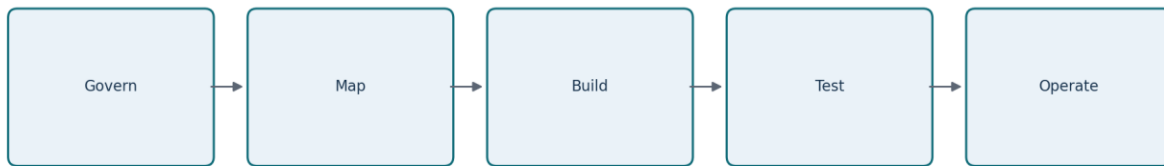


Figure 2. Governance and testing continue throughout the lifecycle.

Generative AI and Prompt Security

A system prompt is not a security boundary. Attackers may use direct or indirect prompt injection to manipulate instructions, reveal data, or trigger tools. Treat all user input and retrieved content as untrusted.

Guardrails reduce risk but cannot guarantee safe behavior. Combine input validation, content filtering, constrained permissions, output validation, monitoring, and human confirmation for consequential actions.

- Separate trusted instructions from untrusted content.
- Do not place secrets in prompts or system instructions.
- Constrain output formats and validate them before downstream use.
- Use allowlists for tools, destinations, and data sources.
- Rate-limit expensive or sensitive operations.
- Red-team multilingual, encoded, obfuscated, and indirect attacks.

RAG Security

RAG grounds model responses in selected documents and also creates a data-retrieval security system. Access control must apply before retrieval, not after the model has seen the content.

A poisoned document can carry hidden or persuasive instructions. Secure ingestion, preserve provenance, scan content, enforce document-level authorization, and display citations so users can verify the answer.

- Approve and inventory source repositories.
- Scan ingestion for malware, secrets, prompt-like instructions and unsupported formats.
- Preserve source, owner, classification, version and ingestion time as metadata.
- Filter retrieval by the requesting identity and business purpose.
- Limit context size and prevent cross-tenant retrieval.
- Evaluate retrieval precision, authorization and citation accuracy.

AI Agents, Tools and MCP

Agents combine model reasoning with memory and tools. MCP standardizes connections between AI clients and servers that expose resources, prompts or tools. The convenience increases the importance of authentication, authorization, and explicit trust boundaries.

Treat every MCP server and agent tool as privileged integration software. A read-only document search tool has a different risk from a tool that sends email, changes firewall rules or executes code.

- Inventory every agent, tool, MCP server, owner and data flow.
- Authenticate both client and server and use encrypted transport.
- Give each agent a dedicated least-privilege identity.
- Require confirmation for irreversible, external or high-impact actions.
- Validate tool parameters and outputs; never execute model text blindly.
- Log tool selection, arguments, policy decision, result and user approval.
- Disable unused tools and provide an immediate kill switch.

Testing and Red Teaming

Testing should demonstrate whether controls work, not merely whether the model answers ordinary questions. Use approved environments and synthetic data. Never test third-party systems without written authorization.

Combine automated evaluation with human review. Tools such as Promptfoo, garak, PyRIT, Giskard and Inspect AI can help organize tests, but results require interpretation and safe configuration.

- Create a threat-based test plan and success criteria.
- Include normal, edge, misuse and adversarial cases.
- Test across languages and user roles.
- Verify both model behavior and surrounding access controls.
- Record prompts, versions, settings, results and reviewer decisions.
- Retest after model, prompt, data, tool or policy changes.

Governance, Compliance and Control Mapping

Use governance frameworks to create a common language, then tailor controls to the actual system. NIST AI RMF, ISO/IEC 42001, ISO/IEC 27001, NIST CSF 2.0, privacy requirements, and sector rules can coexist within a single evidence-driven control program.

A mapping is not proof of compliance. Evidence must show that a control is appropriately designed, assigned to an owner, and operated over time.

- Govern: ownership, policy, risk appetite and accountability.
- Map: context, affected people, data, dependencies and impacts.
- Measure: quality, security, privacy, fairness, resilience and cost.
- Manage: prioritize treatment, approve residual risk and monitor change.
- Maintain a model/system inventory, risk register, control library and evidence repository.

Incident Response for Cloud AI

AI incidents may involve compromised credentials, exposed data, unsafe output, poisoned knowledge sources, abusive automation, unexpected cost, or model-provider changes. Extend the normal incident process to capture model and prompt context.

Preserve evidence without collecting more sensitive content than necessary. Coordinate security, privacy, legal, model owners, business owners, and communications based on severity.

- Triage: confirm scope, affected identities, data, models, tools and users.
- Contain: revoke credentials, isolate endpoints, disable tools, freeze ingestion or revert a model.

- Preserve: protect logs, configurations, prompts, outputs, approvals and relevant versions.
- Eradicate: remove malicious content, close access paths and correct automation.
- Recover: validate controls, monitor closely and obtain business approval.
- Learn: update tests, controls, documentation and training.

Practical Sandbox Lab

This lab creates a small, nonproduction security baseline in IBM Cloud. Use only synthetic data and the lowest-cost eligible services. Delete resources when finished and verify that logging remains available for the required period.

The objective is to practice evidence-based security: every configuration should produce a screenshot, an exported policy, a log event, or a test result that another person can review.

- Create a dedicated nonproduction boundary using enterprise, account, resource groups, regions, and service instances; add owner, purpose, environment, and data-classification tags.
- Federate or secure the administrator with MFA; create a separate daily-use account with limited privileges.
- Configure a private network pattern with IBM Cloud VPCs, subnets, security groups, network ACLs, Transit Gateway, Direct Link and Cloud Internet Services; document allowed inbound and outbound flows.
- Enable IBM Cloud Logs, Activity Tracker Event Routing, Monitoring and Event Notifications and route important administrative events to protected storage.
- Configure IBM Key Protect, Hyper Protect Crypto Services and Secrets Manager; store a test secret and retrieve it through a workload identity rather than embedding it in code.
- Enable or review IBM Cloud Security and Compliance Center and Workload Protection; investigate one finding and record the remediation evidence.
- Deploy a minimal AI experiment using IBM watsonx.ai, watsonx.governance and watsonx.data with synthetic data and no irreversible tools.
- Create ten normal tests and ten adversarial tests, including prompt injection, sensitive-data requests and malformed output.
- Review cost, public exposure, identities, logs and findings; export a small evidence package.
- Delete temporary resources, revoke test credentials and confirm the expected records remain available.

Evidence package

- Architecture diagram
- Exported identity policy
- Network rule summary
- Logging proof
- Key/secret configuration evidence
- Posture finding and remediation
- AI test report
- Cleanup record

Audit Evidence and Operational Checklists

Good evidence is dated, attributable, reproducible and tied to a control. A screenshot alone may omit scope or history; combine it with exported configuration, logs, tickets, approvals and test results.

Review evidence at a frequency appropriate to risk. High-impact agents and sensitive production systems need more frequent access review, testing and monitoring than a public-data demonstration.

- Current architecture and data-flow diagram
- Inventory of models, datasets, agents, tools and non-human identities
- Approved risk assessment and threat model
- Access policies and periodic review results
- Key, secret and certificate lifecycle records
- Security configuration and posture findings
- Evaluation and red-team results with remediation
- Incident exercises, recovery tests and lessons learned

Career Practice and Final Guidance

Cloud AI security is learned by connecting architecture, identity, data, monitoring, testing and governance. Build small authorized projects and publish sanitized diagrams, control mappings and lessons learned rather than credentials or sensitive screenshots.

When presenting this work professionally, explain the business purpose, major risks, decisions, evidence and improvement plan. Employers value clear judgment and communication as much as product-console familiarity.

- Never claim production experience you do not have.
- State what you designed, configured, tested or reviewed.
- Keep a lab journal and version-controlled templates.
- Use vendor training, official documentation and safe practice accounts.
- Teach others; explaining a control is one of the best ways to test understanding.

Glossary

Term	Meaning
AI agent	A system that uses a model to plan or select actions and invoke tools.
Embedding	A numerical representation used to compare semantic similarity.
Guardrail	A policy or technical control intended to constrain input, output or actions.
Hallucination	Plausible-looking output that is unsupported or incorrect.
MCP	Model Context Protocol; a standard for connecting AI clients to resources, prompts and tools.
Non-human identity	An identity used by software, a workload, service, pipeline or agent.
Prompt injection	Untrusted instructions intended to change model behavior or misuse connected capabilities.
RAG	Retrieval-augmented generation; adding retrieved material to

Term	Meaning
	model context.
Vector store	A system that indexes and retrieves embeddings.
Zero Trust	A security approach that verifies explicitly, limits access and assumes breach.

Official Resources and Further Study

Product features, names, prices and regional availability can change. Use these official starting points and verify the documentation applicable to your account and region.

- [IBM Cloud security and compliance](https://cloud.ibm.com/docs/security-compliance) — <https://cloud.ibm.com/docs/security-compliance>
- [IBM Cloud IAM](https://cloud.ibm.com/docs/account?topic=account-iamoverview) — <https://cloud.ibm.com/docs/account?topic=account-iamoverview>
- [Security and Compliance Center](https://cloud.ibm.com/docs/security-compliance) — <https://cloud.ibm.com/docs/security-compliance>
- [Workload Protection](https://cloud.ibm.com/docs/workload-protection) — <https://cloud.ibm.com/docs/workload-protection>
- [IBM watsonx](https://www.ibm.com/docs/en/watsonx) — <https://www.ibm.com/docs/en/watsonx>
- [IBM Cloud Logs](https://cloud.ibm.com/docs/cloud-logs) — <https://cloud.ibm.com/docs/cloud-logs>
- [NIST AI Risk Management Framework](https://www.nist.gov/itl/ai-risk-management-framework) — <https://www.nist.gov/itl/ai-risk-management-framework>
- [NIST Cybersecurity Framework 2.0](https://www.nist.gov/cyberframework) — <https://www.nist.gov/cyberframework>
- [OWASP Top 10 for LLM Applications](https://genai.owasp.org/llm-top-10/) — <https://genai.owasp.org/llm-top-10/>
- [MITRE ATLAS](https://atlas.mitre.org/) — <https://atlas.mitre.org/>
- [Model Context Protocol](https://modelcontextprotocol.io/) — <https://modelcontextprotocol.io/>

This manual is an educational guide, not legal advice or a substitute for vendor support, contractual requirements or a formal compliance assessment.

Appendix: Minimum Control Baseline

Domain	Minimum expectation	Example evidence
Governance	Approved use case, owner, risk tier and prohibited uses	Approval record; system inventory
Identity	MFA, federation, least privilege and separate workload identities	Policy export; access review
Data	Classification, minimization, encryption, retention and deletion	Data flow; key settings; retention record
Network	Private access, restricted ingress and controlled egress	Diagram; rules; flow evidence
AI safety	Injection resistance, output validation, guardrails and human approval	Evaluation report; policy configuration

Domain	Minimum expectation	Example evidence
RAG	Approved sources, provenance and authorization before retrieval	Source inventory; access tests
Agents/MCP	Tool allowlist, dedicated identity, approval and kill switch	Tool inventory; invocation log; shutdown test
Operations	Central logs, alerts, response plan, backup and rollback	Alert test; exercise; recovery evidence